

Non Sequitur Publishing · White Paper

Governance-Gated Execution as an Agentic Zero-Trust Reference Model

Justin H. Kuiper, CISSP

Written: 2026-05-13 · v0.1-seed

Abstract

Zero Trust Architecture (ZTA), formalized in NIST SP 800-207, expresses a structural commitment: no implicit trust on the basis of network location, identity-only authorization, or session-scoped credentials. Every access decision must verify identity, context, and authorization at the moment of access. Agentic systems require an analogous commitment, but the classical ZTA pillars (identity, device, network, data, workload) map imperfectly onto agentic components (persona, context source, tool, action, output surface). This paper develops the mapping and produces an ****Agentic Zero-Trust (AZT) Reference Model**** suitable for NIST/CISA companion guidance.

The thesis is operational: "capability is not permission" restates ZT least-privilege for agentic systems. An agentic system that has the **capability** to call a tool, query a data source, or emit an output is not, by virtue of that capability, **authorized** to do so for a given operator request. Authorization is governance-defined and per-action; capability is a substrate property. The two must remain operationally distinct or the system inherits the implicit-trust failure mode ZT was designed to eliminate.

Section 2 establishes the ZTA-to-agentic mapping and identifies the gaps in current practice. Section 3 specifies the AZT pillars (persona, context source, tool, action, output surface) and the governance-gated execution model that operationalizes them. Section 4 specifies operator-owned policy-as-code as the AZT enforcement surface: every agent action requires a traceable governance decision, encoded in policy artifacts the operator owns and audits. Section 5 places AZT alongside existing controls and discusses the path to standards alignment. Section 6 closes with limitations.

How to cite

Justin H. Kuiper, CISSP (2026). *Governance-Gated Execution as an Agentic Zero-Trust Reference Model* (v0.1-seed). Non Sequitur Publishing. <https://nonsequitur.tech/white-papers/agentic-zero-trust/>

© 2026 Non Sequitur Publishing. All rights reserved. Citation with full attribution is permitted. Reproduction, redistribution, derivative works, and use as input to machine-learning training are **not** permitted without written permission. See <https://nonsequitur.tech/citation-policy/>.
Canonical URL: <https://nonsequitur.tech/white-papers/agentic-zero-trust/>



ABSTRACT

Zero Trust Architecture (ZTA), formalized in NIST SP 800-207,¹ expresses a structural commitment: no implicit trust on the basis of network location, identity-only authorization, or session-scoped credentials. Every access decision must verify identity, context, and authorization at the moment of access. Agentic systems require an analogous commitment, but the classical ZTA pillars (identity, device, network, data, workload) map imperfectly onto agentic components (persona, context source, tool, action, output surface). This paper develops the mapping and produces an **Agentic Zero-Trust (AZT) Reference Model** suitable for NIST/CISA companion guidance.

The thesis is operational: “capability is not permission” restates ZT least-privilege for agentic systems. An agentic system that has the *capability* to call a tool, query a data source, or emit an output is not, by virtue of that capability, *authorized* to do so for a given operator request. Authorization is governance-defined and per-action; capability is a substrate property. The two must remain operationally distinct or the system inherits the implicit-trust failure mode ZT was designed to eliminate.

Section 2 establishes the ZTA-to-agentic mapping and identifies the gaps in current practice. Section 3 specifies the AZT pillars (persona, context source, tool, action, output surface) and the governance-gated execution model that operationalizes them. Section 4 specifies operator-owned policy-as-code as the AZT enforcement surface: every agent action requires a traceable governance decision, encoded in policy artifacts the operator owns and audits. Section 5 places AZT alongside existing controls and discusses the path to standards alignment. Section 6 closes with limitations.

The central claim is that **AZT is not optional for production agentic deployments**: the alternative — implicit trust based on session, capability, or model-vendor identity — recreates the exact failure modes ZTA was designed to eliminate, now exposed to the additional attack surfaces that agentic operation introduces.

HOW TO CITE

Justin H. Kuiper, CISSP (2026). *Governance-Gated Execution as an Agentic Zero-Trust Reference Model* (v0.1-seed). Non Sequitur Publishing.

© 2026 Non Sequitur Publishing. All rights reserved.

1. INTRODUCTION

Zero Trust Architecture is the dominant security architecture for modern enterprise deployment, anchored in NIST SP 800-207 (2020).² Its load-bearing commitment — *never trust, always verify* — eliminated the implicit-trust failure modes of perimeter-based security: an attacker inside the network was not automatically trusted; an authenticated session was not automatically authorized for arbitrary actions; a device on a corporate network was not automatically trustworthy.

1 Scott Rose et al., *Zero Trust Architecture*, NIST Special Publication 800-207 (2020), <https://doi.org/10.6028/NIST.SP.800-207>.

2 Scott Rose et al., *Zero Trust Architecture*, NIST Special Publication 800-207 (2020), <https://doi.org/10.6028/NIST.SP.800-207>.



Agentic systems present an analogous problem at a different layer. An agent has *capabilities* — the set of tools it can call, the data sources it can query, the outputs it can emit. The naive operating model treats capability as permission: if the agent can call tool X, the agent is permitted to call tool X. This treats capability as implicit authorization, which is precisely the failure mode ZTA was designed to eliminate.

The paper develops the analogy and specifies the Agentic Zero-Trust Reference Model. The contribution is to make the classical ZTA pillars operationally specific for agentic systems, and to produce a reference model NIST/CISA companion guidance could adopt.

2. BACKGROUND AND MAPPING

2.1 THE CLASSICAL ZTA PILLARS

NIST SP 800-207 specifies the ZTA tenets³ and CISA's Zero Trust Maturity Model⁴ organizes them into five pillars:

Identity — every actor (human or machine) is uniquely identifiable and authenticated.

Device — every endpoint accessing resources is verified for posture and trust.

Network — micro-segmentation; no implicit trust by network location.

Data — classification and access control at the data layer, not the network layer.

Workload — application-layer authorization; per-workload access policies.

The pillars compose into a runtime authorization fabric: every access decision consults the identity, device, network, data, and workload state for the requesting entity.

³ Scott Rose et al., *Zero Trust Architecture*, NIST Special Publication 800-207 (2020), <https://doi.org/10.6028/NIST.SP.800-207>.

⁴ Cybersecurity and Infrastructure Security Agency, *Zero Trust Maturity Model*, Version 2.0 (2023), <https://www.cisa.gov/zero-trust-maturity-model>.



2.2 THE AGENTIC MAPPING

Agentic systems require an analogous five-pillar model, but the pillars do not map one-to-one:

Classical ZT pillar

Agentic ZT pillar

Mapping note

Identity

Persona

The named agentic identity through which the operating model addresses work. Persona is the authentication subject; persona's authority is operator-pinned.

Device

Context source

The substrate from which the agent assembles its operating context (retrieval corpora, memory stores, tool outputs). Context-source attestation is the device-equivalent.

Network

(deprecated for agentic)

Network-layer trust is irrelevant at the agentic action layer; the network has already passed the request to the agent. Network controls operate upstream.

Data

Tool

The agent's data-layer actions occur through tool calls. Per-tool authorization replaces per-data-resource ACL in the agentic mapping.

Workload

Action

The unit of authorization at the agentic layer is the per-action decision: this specific output, against this specific context, via this specific tool chain, with this specific consequence.



Plus one new pillar that classical ZT does not require:

Output surface — where the agent's output lands (operator-facing channel, downstream system, external recipient). Per-output-surface authorization governs which surfaces a given agent action may reach.

The five-pillar agentic mapping (persona, context source, tool, action, output surface) preserves the structural commitments of classical ZT while specifying them for the agentic execution model.

2.3 WHY THIS MAPPING MATTERS

Without explicit pillar specification, agentic deployments default to implicit-trust patterns:

Capability-as-permission. An agent with tool access is permitted to use the tool for any request, regardless of operator policy. Capability is implicit authorization.

Session-as-permission. An agent operating under a user session inherits the user's full permission set for the session duration, regardless of the specific action class.

Vendor-trust-as-permission. A model vendor's reputation substitutes for per-action operator authorization. The model is "trusted" wholesale; the operator delegates authorization to the vendor implicitly.

Each of these is the agentic analog to a pre-ZTA failure mode in classical enterprise security. The AZT mapping makes the alternatives operationally specific.

3. THE AGENTIC ZERO-TRUST REFERENCE MODEL

3.1 GOVERNANCE-GATED EXECUTION

The AZT operational model is **governance-gated execution**: every agent action passes through a governance gate that consults operator-pinned policy before authorizing the action. The gate is structural — it lives in the agentic runtime, not in the application code — and per-action — it fires for each individual action, not once per session.

The gate's inputs:

Persona — which identity is requesting the action.

Context source — what context substrate is the action operating against (passed through the cyb-02 Context Integrity Baseline first).⁵

Tool — which specific tool is being invoked.

Action — what concrete action is being requested (parameters, target).

Output surface — where the action's result will land.

The gate's decision: *authorized* or *unauthorized* against operator-pinned policy. The gate is structurally fail-closed; unauthorized actions are blocked, not waived.

⁵ Justin H. Kuiper, CISSP, *Context Integrity Failure as the Agentic Cache-Poisoning Analog* (v0.1-seed, 2026), nonsequitur.tech/white-papers/context-integrity-failure/.



3.2 THE FIVE AZT PILLARS IN OPERATION

Persona pillar. Persona identity is authenticated against an operator-managed registry. Persona authority is operator-pinned (which personas may perform which action classes for which operators). The pillar operationalizes the cyb-10 chain-of-custody requirement⁶ by ensuring that every action chains to a named persona-authority pair.

Context source pillar. Context sources are registered with the AZT framework. Each source is authenticated (the source-of-truth is verifiable) and authorized (the source has the operator's permission to contribute to the assemblies in question). Unauthorized sources are rejected at the context boundary; this composes with the cyb-02 Context Integrity Baseline.

Tool pillar. Tools are individually authorized for individual purpose-context-persona triples. The classical principle of least-privilege restated: a persona has the *minimum* tool set required for its authorized actions, not the *maximum* the platform makes available. This composes with the cyb-09 trust-composition discipline⁷ for chained tool calls.

Action pillar. Actions are authorized per-invocation, not per-session. Each invocation produces a structured authorization record (the action, the inputs, the persona, the timestamp, the policy version, the decision). The record feeds the cyb-10 chain-of-custody ledger.

Output surface pillar. Outputs are routed only to surfaces the operator has authorized. A persona authorized to query a data source but not to emit results externally is *not* authorized to forward the query result outside the operator's environment, even though the data source is read-authorized.

4. OPERATOR-OWNED POLICY-AS-CODE

4.1 THE POLICY-AS-CODE SURFACE

AZT enforcement requires policies the operator can author, version, audit, and update. The policies are **policy-as-code**: structured artifacts (typically YAML or Rego/Cedar policy languages)⁸ that specify per-pillar authorization rules.

A representative policy snippet (illustrative):

policies:

```
-
  name: "persona-clive-build-actions"
  persona: clive
  allowed_tools: [github_pr_create, file_edit, git_commit]
  allowed_output_surfaces: [yks-build-repo, yks-spine-binder-issues]
  context_sources: [yks-build-files, yks-spine-binder-refs]
  purpose_bindings:
    - purpose: "white-paper-drafting"
      max_action_consequence: bounded
```

⁶ Forthcoming CYB-10 *Human Authority Boundary as Chain-of-Custody for Agentic Outputs* (in concurrent drafting; this dispatch).

⁷ Forthcoming CYB-09 *Tool Orchestration as a Confused-Deputy and Privilege-Compounding Surface* (in concurrent drafting; this dispatch).

⁸ Tim Hinrichs et al., "Open Policy Agent: A Policy Language for the Cloud-Native Era," *ACM SoCC '18*, 2018.



```
- name: "persona-clive-external-disabled"
  persona: clive
  disallowed_output_surfaces: ["*-external-*"]
  disallowed_actions: ["api_call:public_*"]
```

The operator owns these artifacts. Policy changes are versioned, reviewable, and audit-logged.

4.2 PER-ACTION GOVERNANCE DECISIONS

Every agentic action produces a *traceable governance decision*: a record naming the policy version that authorized the action, the gate's input state, and the decision outcome. The record is durable and consult-able.

The implication for auditability: an after-the-fact review can answer "by what authority did this action occur?" by consulting the governance-decision record. Without per-action records, the answer is "by virtue of the persona's session-level authority," which is the implicit-trust pattern AZT eliminates.

4.3 NO AGENT ACTION WITHOUT A TRACEABLE GOVERNANCE DECISION

The structural requirement: no agent action proceeds without a governance-decision record. Actions for which the gate cannot produce a decision (because policy is missing, ambiguous, or expired) fail-closed: the action is blocked and surfaced to the operator for policy resolution.

This requirement composes with the parent HGC³AE²'s commitment to human-governed authority: the operator's policy is the runtime expression of the operator's governance.⁹ An agent operating outside the operator's policy is operating outside the operator's authority, regardless of model capability.

5. FRAMEWORK PLACEMENT

5.1 RELATIONSHIP TO EXISTING STANDARDS

AZT extends NIST SP 800-207 (Zero Trust Architecture)¹⁰ into the agentic operational domain. The extension is constructive: existing ZTA components (Policy Decision Point, Policy Enforcement Point, Policy Information Point) translate to agentic equivalents with documented mapping. CISA's Zero Trust Maturity Model¹¹ can be extended with an agentic dimension; this paper supplies the source material for that extension.

OWASP LLM Top 10 covers some adjacent surfaces (LLM07 plugin design, LLM08 excessive agency).¹² AZT is the architectural frame that operationalizes the LLM08 discipline at runtime.

⁹ Justin H. Kuiper, CISSP, *Mitigating Confident Misalignment in Agentic Systems: The HGC³AE² Framework* (v1.0-preprint, 2026), zenodo.org/records/19869285.

¹⁰ Scott Rose et al., *Zero Trust Architecture*, NIST Special Publication 800-207 (2020), <https://doi.org/10.6028/NIST.SP.800-207>.

¹¹ Cybersecurity and Infrastructure Security Agency, *Zero Trust Maturity Model*, Version 2.0 (2023), <https://www.cisa.gov/zero-trust-maturity-model>.



5.2 RELATIONSHIP TO FAMILY THESES

AZT composes with the other HGC³AE² cyber-pillar theses:

cyb-01 (confident-misalignment-attack-surface)¹³ — AZT's output-surface pillar bounds where adversarial outputs may propagate, narrowing the attack surface confident-misalignment exploits.

cyb-02 (context-integrity-failure)¹⁴ — AZT's context-source pillar requires CIB-attested sources, composing with CIB's three properties.

cyb-03 (denial-of-validation)¹⁵ — AZT's policy-as-code includes fail-visible signaling; validation disruption is observable through governance-decision records.

cyb-09 (tool-orchestration-trust-composition)¹⁶ — AZT's tool pillar bounds individual tool authorization; cyb-09 develops the compositional discipline for chained tool calls.

cyb-10 (human-authority-chain-of-custody)¹⁷ — AZT's governance-decision records are the chain-of-custody entries cyb-10 specifies.

6. LIMITATIONS AND CONCLUSION

6.1 LIMITATIONS

The policy-as-code requirement assumes operators have the time, expertise, and tooling to author and maintain per-action policies. In high-volume deployments, policy authoring may be outsourced to platform vendors with operator review; this introduces vendor-trust patterns the framework was designed to limit.

The five-pillar mapping is a starting point. Production deployments may require additional pillars (model-vendor attestation, regulatory-domain mapping, temporal-policy scoping) not developed here.

The runtime gate adds latency to every agent action. In low-stakes high-volume contexts the latency may be unacceptable; partial-gate optimizations (cached decisions, batched evaluation) are engineering complements not specified in this thesis.

12 OWASP, *OWASP Top 10 for Large Language Model Applications* (2024), <https://owasp.org/www-project-top-10-for-large-language-model-applications/>.

13 Justin H. Kuiper, CISSP, *Confident Misalignment as an Adversarial Attack Surface* (v0.1-seed, 2026), nonsequitur.tech/white-papers/confident-misalignment-attack-surface/.

14 Justin H. Kuiper, CISSP, *Context Integrity Failure as the Agentic Cache-Poisoning Analog* (v0.1-seed, 2026), nonsequitur.tech/white-papers/context-integrity-failure/.

15 Justin H. Kuiper, CISSP, *Silent Fallback as a Denial-of-Validation Attack* (v0.1-seed, 2026), nonsequitur.tech/white-papers/denial-of-validation/.

16 Forthcoming CYB-09 *Tool Orchestration as a Confused-Deputy and Privilege-Compounding Surface* (in concurrent drafting; this dispatch).

17 Forthcoming CYB-10 *Human Authority Boundary as Chain-of-Custody for Agentic Outputs* (in concurrent drafting; this dispatch).



6.2 CONCLUSION

Zero Trust Architecture's structural commitments — no implicit trust on identity, location, or session — apply to agentic systems with appropriate translation. The Agentic Zero-Trust Reference Model develops the translation: five pillars (persona, context source, tool, action, output surface), governance-gated execution, operator-owned policy-as-code. The model produces a deployment-ready framework that NIST/CISA companion guidance could adopt for production agentic systems.

The central claim: **capability is not permission**. An agentic system that conflates the two recreates the failure modes ZTA was designed to eliminate. AZT is the architectural translation that preserves ZTA's structural commitments at the agentic execution layer.

This is Thesis Six (cyb-06) of the HGC³AE² Cyber Pillar derivative family.

REFERENCES

— end v0.1-seed draft —

Drafting state: v0.1 CYB-06 (chain v0.1 step 4). 6-section canon shape adapted for ZTA-extension thesis. PR count: 12 — parent (HGC³AE²) + NIST SP 800-207 + CISA ZTMM + OPA + OWASP LLM + Saltzer/Schroeder + Miller object-cap + Cedar + 4 cross-thesis refs (cyb-01, cyb-02, cyb-03, cyb-09/10 forward). Meets ≥12 floor.